MAGNETAR LEGAL AUDIT

EXECUTIVE SUMMARY

The contract contains multiple critical compliance failures exposing the Customer to significant legal and financial risks, including unlawful broad data usage for AI training, improper data transfer waivers, and inadequate audit rights. These issues violate core GDPR principles such as purpose limitation and transparency, as well as the EU AI Act's data governance and transparency mandates. Immediate renegotiation is essential to avoid regulatory sanctions, financial penalties, and reputational harm.

COMPLIANCE SCORE: 35/100

CRITICAL FINDINGS

[CRITICAL] Violation

Clause: "8.2 Training on Customer Data (Red-Flag Clause). Customer grants Provider the right to use Customer Data and all outputs to train, improve, and benchmark Provider models for any purpose, including for other customers, even after termination, without further notice."

Why: This clause violates GDPR Article 5(1)(b) on purpose limitation by permitting processing beyond the specified, explicit, and legitimate purposes without further consent or transparency, and conflicts with the EU AI Act's transparency and data governance requirements. The indefinite and broad use of Customer Data for AI training without explicit, informed consent breaches GDPR principles and undermines data subject rights.

Correction: Customer grants Provider the right to use Customer Data solely for the purpose of providing the Services during the Subscription Term. Any use of Customer Data for AI training or model improvement beyond the Subscription Term requires explicit prior consent and compliance with applicable data protection laws, including transparency obligations. [See GDPR Article 5(1)(b), Articles 12-14; EU AI Act transparency requirements; https://www.ketch.com/blog/posts/purpose-limitation-meaning; https://commission.europa.eu/law/law-topic/data-protection/rules-business-and-organisations/principles-gdpr/purpose-data-processing/can-we-use-data-another-purpose_en]

[CRITICAL] Violation

Clause: "9.1 Processing Locations (Red-Flag Clause). Provider may process Customer Data anywhere in the world, including outside the EEA/UK, and Customer waives any requirement for transfer safeguards."

Why: GDPR Chapter V mandates that transfers of personal data outside the EEA/UK must be subject to appropriate safeguards such as adequacy decisions or Standard Contractual Clauses. Waiving these safeguards is unlawful and exposes the Customer to regulatory penalties and data subject rights violations. This also conflicts with the EU AI Act's data governance requirements for high-risk AI systems.

Correction: Provider shall process Customer Data only within jurisdictions that ensure an adequate level of data protection as recognized by the European Commission or under appropriate transfer mechanisms such as Standard Contractual Clauses. Any transfer outside these jurisdictions requires Customer's prior written consent. [See GDPR Chapter V; https://www.ketch.com/blog/posts/purpose-limitation-meaning]

[HIGH] Violation

Clause: "10.1 Audit (Red-Flag Clause). Customer may audit Provider's compliance only once every 5 years, with 60 days notice, and only by a Provider-selected auditor."

Why: Restricting audit rights to once every five years, requiring Provider-selected auditors, and imposing long notice periods severely limit the Customer's ability to verify compliance with GDPR and the EU AI Act, undermining accountability and transparency obligations under both regulations.

Correction: Customer may conduct audits of Provider's compliance with data protection and AI regulatory obligations at reasonable intervals, with at least 30 days' prior written notice, and may select an independent auditor subject to reasonable confidentiality obligations.

[CRITICAL] Violation

Clause: "12.1 Deletion (Red-Flag Clause). Provider may retain Customer Data and derived analytics indefinitely for "service improvement," compliance, and internal business purposes."

Why: GDPR Article 5(1)(e) requires personal data to be kept no longer than necessary for the purposes for which it was processed. Indefinite retention without clear limits violates storage limitation principles and data subject rights. The EU AI Act also mandates data minimization and purpose limitation for AI training data.

Correction: Provider shall retain Customer Data only for the duration necessary to provide the Services and for any legally required retention periods. Upon termination or expiration, Provider shall delete or return Customer Data within a reasonable timeframe, except where retention is required by law.

[HIGH] Violation

Clause: "14.1 Liability Cap (Red-Flag Clause). Provider's total liability is limited to the fees paid in the last 30 days."

Why: A liability cap limited to 30 days' fees is unreasonably low and exposes the Customer to significant financial risk, especially in cases of data breaches or AI-related harms. GDPR and the EU AI Act impose strict liability and accountability standards that cannot be contractually waived or limited to such an extent.

Correction: Provider's liability shall not be limited in cases of willful misconduct, gross negligence, or breaches of data protection obligations, including data breaches. For other claims, liability shall be capped at the total fees paid under the Agreement in the preceding 12 months.

[CRITICAL] Violation

Clause: "14.3 Security Breach Carve-Out (Red-Flag Clause). The liability cap applies even for breaches of confidentiality, security incidents, and data protection violations."

Why: Applying liability caps to data protection violations and security breaches contravenes GDPR Articles 82 and 83, which require effective remedies and sanctions. This clause undermines the Customer's right to full compensation for damages caused by such breaches.

Correction: Liability caps shall not apply to damages arising from breaches of confidentiality, security incidents, or violations of data protection laws, ensuring full indemnification for such events.

[HIGH] Violation

Clause: "16.1 Provider may use Customer's name and logo in marketing materials without prior approval."

Why: Using Customer's name and logo without prior consent may violate GDPR's transparency and consent requirements and could infringe on trademark or publicity rights, posing reputational risks to the Customer.

Correction: Provider may use Customer's name and logo in marketing materials only with Customer's prior written consent, which shall not be unreasonably withheld.

[HIGH] Violation

Clause: "18.3 Order of Precedence (Red-Flag Clause). In conflict, this MSA overrides the DPA."

Why: The Data Processing Agreement contains mandatory GDPR provisions that cannot be overridden by the MSA. This clause risks nullifying critical data protection obligations and exposes the Customer to regulatory non-compliance.

Correction: In the event of any conflict between this Agreement and the Data Processing Agreement, the provisions of the Data Processing Agreement shall prevail to the extent necessary to ensure compliance with applicable data protection laws.
